BOOSTHUB STAKING V2

Independent-review process / Sealed August 23, 2026

FINAL SECURITY VERDICT

PASS

Seven validated Low-severity findings

Four verified fixes / Three accepted residual risks

8	114	0
SOURCE FILES REVIEWED	ENTRYPOINTS REVIEWED	MEDIUM / HIGH / CRITICAL

Scope: audited smart contracts only. No production deployment attestation is claimed.

This release links seven selected public evidence files; the source ZIP is not published.

Executive security assessment

COMPLETED REVIEW • SECURITY VERDICT: PASS

The completed V7 audit validated seven Low-severity findings. Four were remediated and independently verified. The remaining three are expressly accepted as marginal, bounded economic impact; they are not fixed.

What was examined

Vault and staking-contract principal flows, reward accounting, share issuance, conversion routes, governance privileges, token interfaces and external dependency behavior.

What the verdict means

No unresolved unaccepted security findings remain within the admitted smart-contract scope. The three accepted Low findings remain present and are identified by finding ID.

Security assurance boundaries

The review assessed source-bound contract behavior and recorded test evidence. It does not certify deployment scripts, release tooling, operator workflow, future market conditions or production configuration.

Assurance independence

The recorded reviewer model is procedural independence only. This report does not claim a blind external third-party audit.

Audit footprint

CODEBASE

5 Implementations reviewed	**3** Interfaces examined	**8** Audited source files	**2** Source languages
114 Reviewed entrypoints	**9** Authority actor categories	**7** Protected capital classes	**6** Documented trust boundaries

ARCHITECTURE AND SCOPE

17 Mapped asset-flow edges	**10** Assessed security domains	**6** Applicable security domains	**1** External staking platform
0 Cross-chain domains	**0** Upgrade-proxy domains	**0** Lending domains	**0** Signature-specific domains

Depth of security investigation

THREAT ANALYSIS

26 Positive security requirements	**22** Negative security requirements	**28** Specified invariants	**10** Modeled threat scenarios
23 Attack-tree branches	**7** Critical invariant families	**130** Neutral Slither observations	**114** Entrypoints manually reviewed

VALIDATION AND EXECUTION

9 Substantive candidates	**9** Candidates dispositioned	**2** Dismissed candidates	**0** Inconclusive candidates
6 Dynamically evidenced candidates	**7** Validated security findings	**4** Verified remediations	**3** Accepted residual findings

Findings and resolution

7 LOW

No validated Critical, High or Medium findings

4	3
FIXED / VERIFIED	ACCEPTED LOW

VALIDATED FINDING SEVERITY

CANDIDATE DISPOSITION

Promoted to validated findings	7
Dismissed after assessment	2
Remaining inconclusive	0

System architecture and trust

Canonical principal-flow model; arrows describe accepted high-level interactions.

Principal and shareholder accounting

Deposits and redemptions flow through the Vault and Strategy; the staking system manages withdrawal queues and reward liability.

Reward conversion and price sensitivity

External Curve-style liquidity and quote paths affect reward conversion and estimated unharvested values. The remediated converter enforces oracle-aware tolerance.

Privileged control boundaries

Token minting, fee and reward configuration, rescue delays, and staking configuration are controlled by distinct authority roles.

Independent external dependencies

BoostHub, ERC-20 assets, reward converters, Curve pools and ChildGauge integrations introduce external liveness or trust assumptions.

Adversarial verification

01

Medusa fuzzing

The recorded Medusa terminal campaign tested source-bound security behavior and produced a decisive candidate reproduction.

02

Native fuzz execution

Foundry native fuzzing was invoked after Medusa; the recorded 10,000-run requested budget found a counterexample to the deposit property.

03

Deterministic candidates

Six carried candidate mechanisms received dynamic execution evidence during Phase 6; this does not imply six validated vulnerabilities.

04

Pinned Ethereum fork

Phase 7 exercised staking, harvest, withdrawal, conversion and reward behavior on a pinned Ethereum fork, including sdCRV, sdFXN and sdYB paths.

05

Independent remediation verification

Phase 9 recorded four independently verified remediations, including executable converter routes, stale rescue timer, sdYB classification and tolerance bounds.

LOW-SEVERITY SECURITY FINDINGS

Four fixed-size boxes per severity page. Open slots remain blank.

BH-V2-LOW-001

ACCEPTED RESIDUAL

Vault reward-preview valuation can marginally affect share issuance

DESCRIPTION

The Vault's standard-deposit accounting can allow a new depositor to receive a marginal share advantage when the value attributed to already-accrued but unharvested rewards is temporarily depressed. Pinned-fork testing reproduced the effect, but the demonstrated economic impact was very small and no scalable profitable extraction loop was established.

SECURITY IMPACT Marginal share-issuance advantage from temporary reward valuation distortion.

Complete evidence and disposition: Findings_and_Remediation.json

BH-V2-LOW-002

FIXED / VERIFIED

Converter fair-value / execution protection

DESCRIPTION

The original conversion design could use insufficiently independent market-derived values for conversion protection, allowing reachable reward-processing liveness failures under adverse market conditions.

SECURITY IMPACT Conversion protection could cause harvest-liveness failure during price divergence.

Complete evidence and disposition: Findings_and_Remediation.json

BH-V2-LOW-003

ACCEPTED RESIDUAL

Disabled reward-route balances can become owner-rescuable

DESCRIPTION

After a reward route is disabled and the contractual rescue delay completes, reward-token balances held by the Strategy can become rescuable by the privileged owner. The behavior is limited to reward-token value, requires privileged action, and does not expose deposited principal.

SECURITY IMPACT Privileged owner may rescue disabled-route reward-token balances after delay.

Complete evidence and disposition: Findings_and_Remediation.json

BH-V2-LOW-004

ACCEPTED RESIDUAL

Residual reward carry can become stranded after reward disablement

DESCRIPTION

A residual reward_remaining balance can remain recoverable while the reward remains enabled, but disabling the reward can remove the later rescheduling path that otherwise distributes that carry. The condition requires the relevant reward-state sequence and does not affect deposited principal.

SECURITY IMPACT Disabled reward route may prevent later distribution of residual carry.

Complete evidence and disposition: Findings_and_Remediation.json

LOW-SEVERITY SECURITY FINDINGS

Four fixed-size boxes per severity page. Open slots remain blank.

BH-V2-LOW-005

FIXED / VERIFIED

Stale rescue-timer pre-aging

DESCRIPTION

The original Strategy could retain an old tokenRescueReadyAt timestamp across reward-route re-enablement, allowing a later disable/rescue cycle to inherit a previously matured timer instead of receiving a fresh delay.

SECURITY IMPACT Pre-aged rescue timer could bypass a fresh warning interval.

Complete evidence and disposition: Findings_and_Remediation.json

BH-V2-LOW-006

FIXED / VERIFIED

sdYB WANT / BoostHub-native reward classification incompatibility

DESCRIPTION

The original staking constructor could incorrectly require the configured WANT to also be registered as a BoostHub-native reward. For the sdYB pool, this prevented the intended staking contract construction because sdYB is the WANT but is not a native BoostHub reward token.

SECURITY IMPACT Incorrect WANT classification could block sdYB staking construction.

Complete evidence and disposition: Findings_and_Remediation.json

BH-V2-RR2-LOW-001

FIXED / VERIFIED

Exact oracle preview used as staking fee-conversion minOut

DESCRIPTION

The first remediation round corrected converter pricing but left the staking contract passing its oracle-derived preview as an exact minimum output. Normal oracle-versus-executable-price divergence could therefore revert fee conversion even without a security-significant price anomaly.

SECURITY IMPACT Exact oracle preview as minOut could revert otherwise normal fee conversions.

Complete evidence and disposition: Findings_and_Remediation.json

Remediation and residual risk

FOUR INDEPENDENTLY VERIFIED FIXES

BH-V2-LOW-002	Converter fair-value / execution protection
BH-V2-LOW-005	Stale rescue-timer pre-aging
BH-V2-LOW-006	sdYB WANT / BoostHub-native reward classification incompatibility
BH-V2-RR2-LOW-001	Exact oracle preview used as staking fee-conversion minOut

THREE EXPRESSLY ACCEPTED LOW FINDINGS

BH-V2-LOW-001	Vault reward-preview valuation can marginally affect share issuance
BH-V2-LOW-003	Disabled reward-route balances can become owner-rescuable
BH-V2-LOW-004	Residual reward carry can become stranded after reward disablement

These accepted issues remain unfixed. They are documented as marginal, bounded economic impact, not as eliminated risk. Further code or configuration changes require their own source-bound review before any equivalence to this audit may be claimed.

Explore the audit evidence

SEVEN SELECTED PUBLIC FILES / SOURCE ZIP NOT PUBLISHED

01 **Audit scope**
Contracts, interfaces and admitted review boundaries
OPEN PUBLIC RECORD

02 **Findings and remediation**
Seven validated findings and their final outcomes
OPEN PUBLIC RECORD

03 **Methodology and analysis**
Aggregated security assessment and technical work
OPEN PUBLIC RECORD

04 **Evidence index**
Selected public evidence and file integrity references
OPEN PUBLIC RECORD

05 **Execution results**
Adversarial reproductions and deterministic outcomes
OPEN PUBLIC RECORD

06 **Medusa fuzz results**
Fuzzing terminal evidence
OPEN PUBLIC RECORD

07 **Native fuzz results**
Additional native fuzzing evidence
OPEN PUBLIC RECORD

These files were already publicly released as sanitized audit evidence. No source ZIP has been reconstructed or published. This report creates no links into private audit infrastructure.